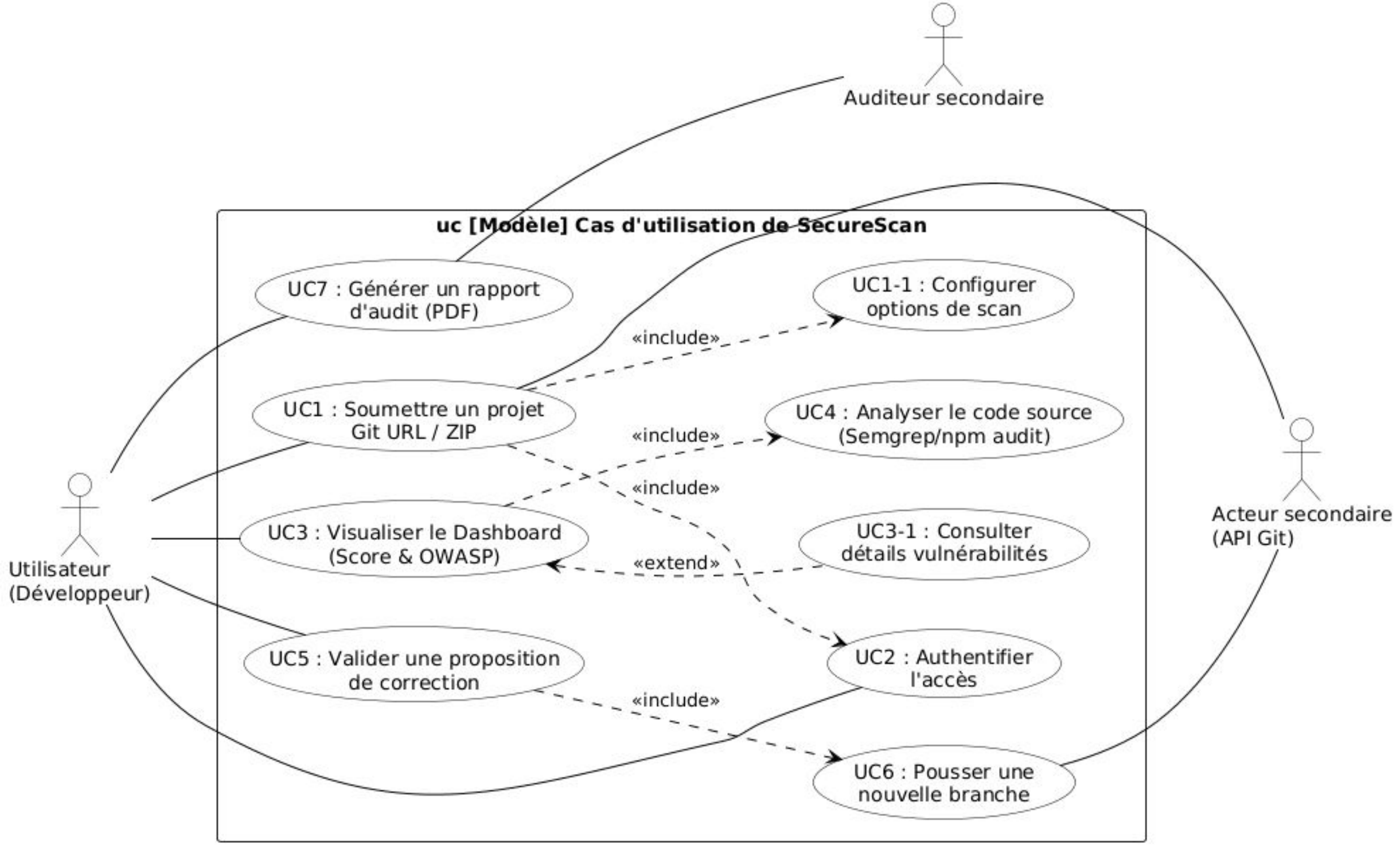
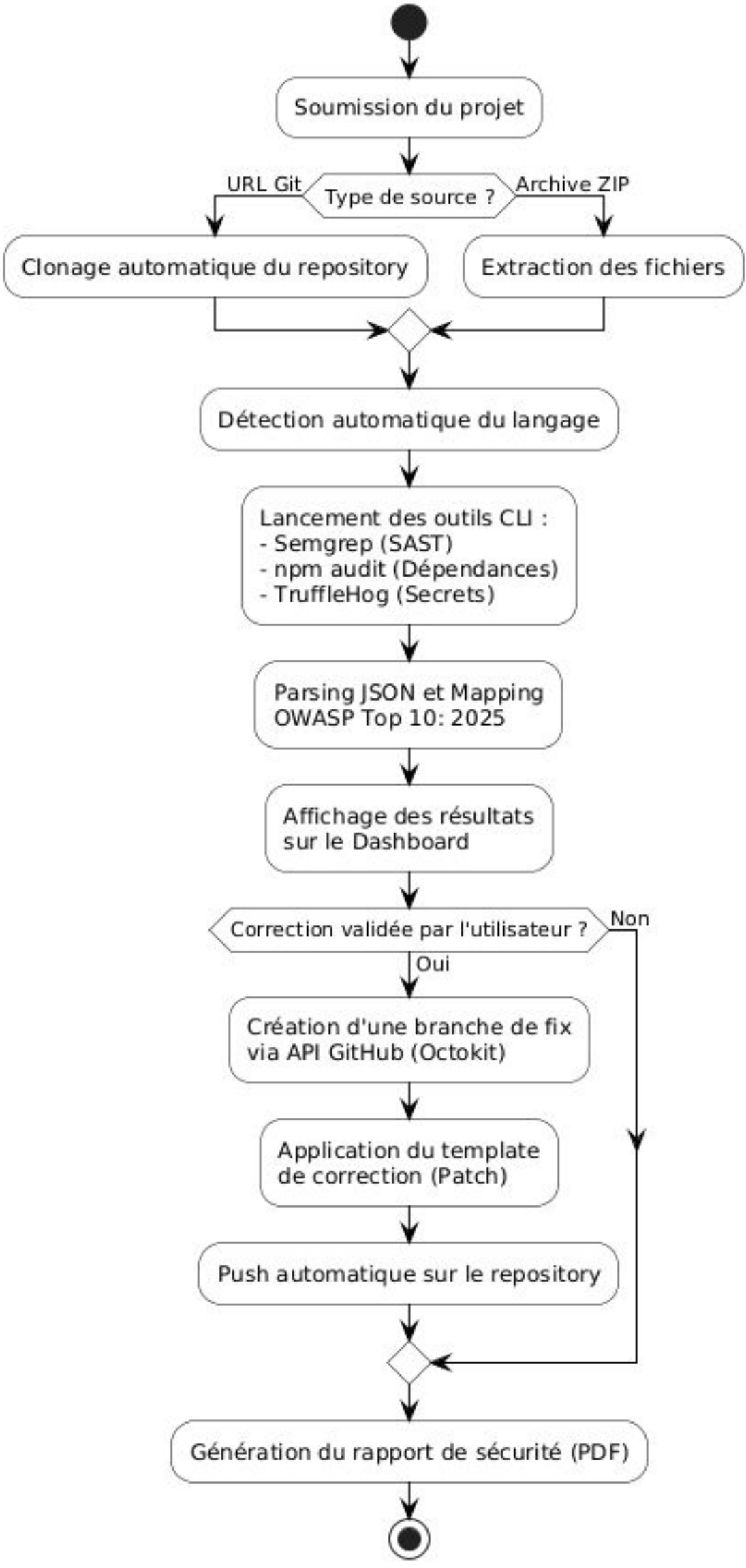
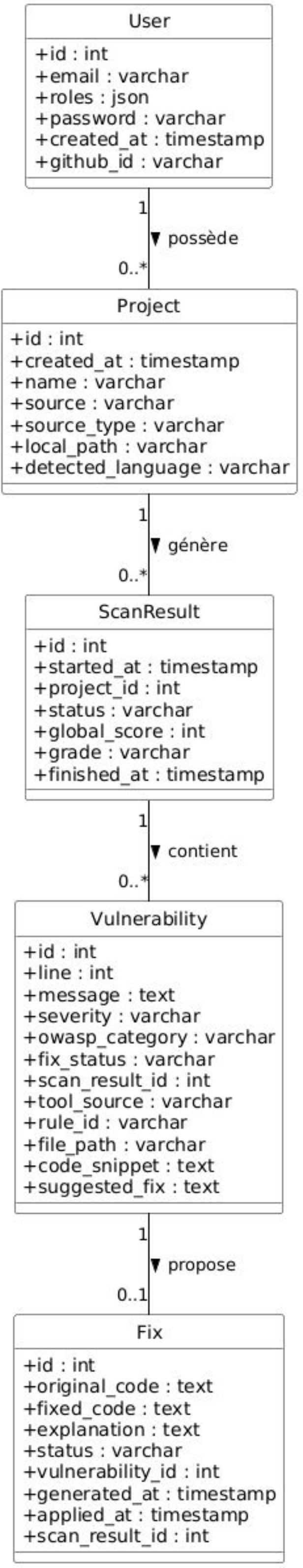
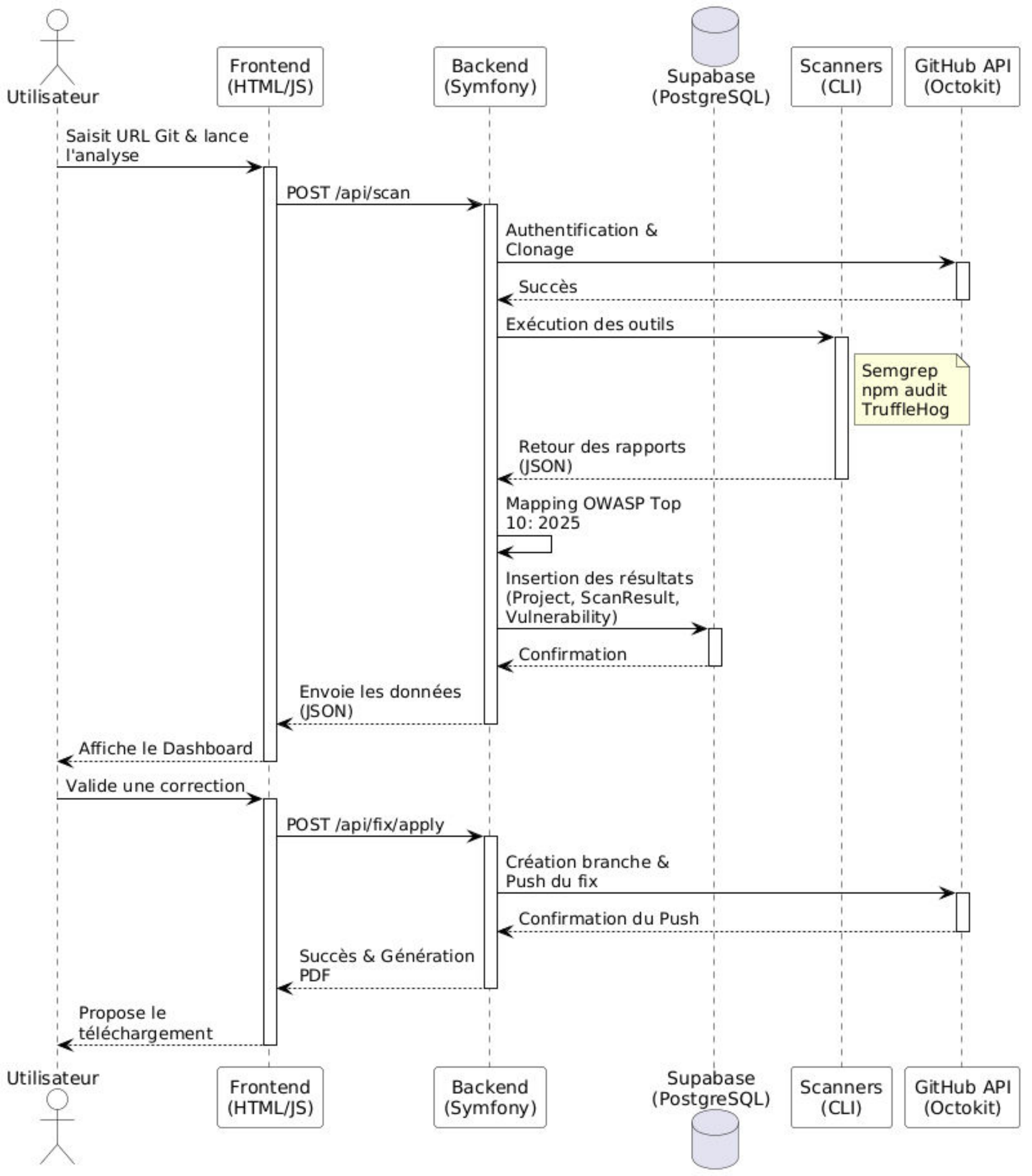

Auditeur secondaire
uc [Modèle] Cas d'utilisation de SecureScan
UC7 : Générer un rapport d'audit (PDF)
UC1-1 : Configurer options de scan
«include»
UC1 : Soumettre un projet Git URL / ZIP
UC4 : Analyser le code source (Semgrep/npm audit)
«include»
«include»
UC3 : Visualiser le Dashboard (Score & OWASP)
UC3-1 : Consulter détails vulnérabilités
«extend»
Utilisateur (Développeur)
Acteur secondaire (API Git)
UC5 : Valider une proposition de correction
UC2 : Authentifier l'accès
«include»
UC6 : Pousser une nouvelle branche


Soumission du projet
Type de source ?
URL Git
Archive ZIP
Clonage automatique du repository
Extraction des fichiers
Détection automatique du langage
Lancement des outils CLI :
- Semgrep (SAST)
- npm audit (Dépendances)
- TruffleHog (Secrets)
Parsing JSON et Mapping
OWASP Top 10: 2025
Affichage des résultats
sur le Dashboard
Correction validée par l'utilisateur ?
Non
Oui
Création d'une branche de fix
via API GitHub (Octokit)
Application du template
de correction (Patch)
Push automatique sur le repository
Génération du rapport de sécurité (PDF)


User
+id : int
+email : varchar
+roles : json
+password : varchar
+created_at : timestamp
+github_id : varchar
1
possède
0..*
Project
+id : int
+created_at : timestamp
+name : varchar
+source : varchar
+source_type : varchar
+local_path : varchar
+detected_language : varchar
1
génère
0..*
ScanResult
+id : int
+started_at : timestamp
+project_id : int
+status : varchar
+global_score : int
+grade : varchar
+finished_at : timestamp
1
contient
0..*
Vulnerability
+id : int
+line : int
+message : text
+severity : varchar
+owasp_category : varchar
+fix_status : varchar
+scan_result_id : int
+tool_source : varchar
+rule_id : varchar
+file_path : varchar
+code_snippet : text
+suggested_fix : text
1
propose
0..1
Fix
+id : int
+original_code : text
+fixed_code : text
+explanation : text
+status : varchar
+vulnerability_id : int
+generated_at : timestamp
+applied_at : timestamp
+scan_result_id : int


Utilisateur
Frontend (HTML/JS)
Backend (Symfony)
Supabase (PostgreSQL)
Scanners (CLI)
GitHub API (Octokit)
Saisit URL Git & lance l'analyse
POST /api/scan
Authentification & Clonage
Succès
Exécution des outils
Semgrep
npm audit
TruffleHog
Retour des rapports (JSON)
Mapping OWASP Top 10: 2025
Insertion des résultats (Project, ScanResult, Vulnerability)
Confirmation
Envoie les données (JSON)
Affiche le Dashboard
Valide une correction
POST /api/fix/apply
Création branche & Push du fix
Confirmation du Push
Succès & Génération PDF
Propose le téléchargement
Utilisateur
Frontend (HTML/JS)
Backend (Symfony)
Supabase (PostgreSQL)
Scanners (CLI)
GitHub API (Octokit)